

WWW Security

Module 20

Duration: 26:21

Video: <https://www.youtube.com/watch?v=4t3ot0oUah0>

Course Coordinator - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Subject Expert - Dr Gursimran Singh, Doaba College, Jalandhar

Auto-generated YouTube transcript for personal study. Spoken wording belongs to the original lecture. Follow the video link above; this file is not an official CEC/SWAYAM publication.

hello everyone this is gur simran Singh welcome to the session of worldwide web security www the worldwide web is one of the biggest invention ever it is also the biggest information resource of the world it has opened flood gates of information and enables instant access to information anywhere anytime and in any format www is now contributing to the globalization of production and capital markets by reducing the cost of information and communication the www has proved to be a producing ground for a large and growing number of e business that carried out most of their sales and services over the Internet the worldwide web is fundamentally a client server application running over the internet and TCP IP internets information stored on

www is in the form of electronic documents called web pages now web browser is used to access the information on worldwide web the new services are introduced every day online banking online transactions it requires special security attention but web presents new challenges not generally appreciated in the context of Computer and Network Security so these are the internet is two-way unlike traditional publishing environment even electronic publishing system involving teletext voice response or faxback the web is vulnerable to attacks on the web servers over the Internet the web is increasingly serving as a highly visible outlet for corporate and product information and as the platform for business

transactions reputations can be damaged and money can be lost if web servers are challenged although web servers are easy to use web servers are relatively easy to configure and manage and web content is increasingly easy to develop and underlying software is extraordinary complex this complex software May hide many potential security flaws the short history of the web is filled with the examples of new and upgraded systems properly installed that are vulnerable to a variety of security attacks a web server can be exploited as a launching pad into corporations or agencies computer complex once the web server is subverted and attacker can able to gain access to data and systems not part of the web itself but connected to the

server at the local site now casual and untrained users are common clients for web based services such as users are not necessarily aware of security risk that exist and do not have the tools or knowledge is to take effective Counter measures now let's discuss worldwide web security threats worldwide web security threats can be grouped in terms of passive and active attacks passive attacks include EES dropping on network traffic between browser and server and gaining access to information on a website that is supposed to be restricted active attacks include impersonating another users altering 4 minutes, 1 second message in transmission between client and server and altering information on a website main WWW security threats can be

briefed as Integrity threats confidentiality threats authentication threats and denial of service attack now we will discuss different threats with consequences and counter measures so let's start our discussion with the first security threat that is Integrity threats data integrity means keeping the data intact the main threats to data Integrity on worldwide web are modification of user data trojan horse browser modification of memory modification of message traffic in transmission now the consequences of Integrity threats are loss of information compromise of machine vulnerability to all other threats countermeasure of Integrity threats is cryptographic traffic check SS now the second threat is confidentiality threat

the main threats to data confidentiality on worldwide web are EES dropping on the internet theft of information from the server theft of data from client and information about network configuration information about which client talks to server now consequences of confidentiality threats are loss of information and loss of privacy now cont ERS are encryptions and web proxies now next threat is authentication threat the main threats to authentication on worldwide web are impersonating of legal users and data forgery consequences of authentication threats are misrepresentation of user believe that false information is valid now Counter measures for authentication threats is use of cryptographic

6 minutes, 1 second techniques now next threat is that is the most dangerous denial of service attack the main threat of denial of service attacks are killing of user threats flooding machine with bogus requests filling up disk or memory isolating Machine by DNS attacks consequences of denial of service attacks are disruptive annoying prevent users from getting work done now counter measures of denial of service it is very difficult to prevent the denial of service attack now there are certain web traffic security approaches that can provide web security the various approaches that have been considered are similar in the service they provide and to some extent in the mechanism that they use but they differ with respect to their scope and applications and their

relative location within the tcpip protocol stack now worldwide web security can be provided on network layer transport layer application layer and as well as by using the firewalls now let's start our discussion with web security at Network level IP security is one way to provide web Security on network layer IP security is a collection of protocols designed by the internet

engineering task force to provide security for a package at Network level the advantage of using IP security is that it is transparent to end users and applications and provides a general purpose solution further IP security includes a filtering capability so that only selected traffic need experience the overhead of Ip security

processing the figure that is displayed on the screen represents the use of Ip security to provide the worldwide web security IP security helps in creating authenticated and confidential packets for IP layer IP security operates in two different modes transparent mode and tunnel mode so in transport mode IP security protects what is delivered from the transport layer to the network layer in other words transport mode protects the payload to be encapsulated in the network layer as you can observe in the figure note that transport mode does not protect the whole IP header it protects only the packet from the transport layer the IP layer payload in this mode the IP security header and trailer are added to the information coming from the

transport layer the IP header is added later on as you can observe in the figure transport mode is normally used when we need host to host protection of data the sending host uses IP security to authenticate or encrypt the payload delivered from the transport layer the receiving host uses IP security to check the authentication or decrypt the IP packet and deliver it to the above layer that is transport layer now the second mod is tunnel mode in tunnel mode IP security protects the entire packet it takes an IP packet includes the header applies IP security methods to the entire packet and then adds a new IP header as you can observe in the figure the new IP header has different information than the original Ip header tunnel mode is normally used between two

routers between a host and a router or between a router and a host as you can 10 minutes, 1 second observe in the figure displayed the entire original packet is protected from intrusion between the sender and the receiver as if the whole packet goes through an imaginary tunnel now if you will compare transport and tunnel mode in transport mode the IP security layer comes between the transport layer and the network layer internal mode the flow is from Network layer to the IP security layer and then back to the network layer again as you can observe in the figure it Compares tunnel mode and transparent mode now IP security defines two protocols the authentication header protocol and encapsulating security payload ESP protocol to provide the

authentication or encryption for packets at the IP level we will discuss these protocols briefly here let's have a quick look on authentication header first the authentication header protocol is designed to authenticate the source sord and to ensure the Integrity of the payload carried in the IP packet the protocol uses a hash function and symmetric key to create a message digest the digest is inserted in the authentication header the authentication header is then placed in the appropriate location based on the mode whether it can be transport called tunnel mode figure shows the field and the positions of the authentication header in the transport

mode now encapsulating security payload that is ESP the ah protocols does not provide confidentiality only source

authentication and data Integrity IP security later defines an alternative protocol that provides Source authentication integrity and confidentiality. ESP adds a header and trailer note that ESP's authentication data are added at the end of the packet which make its calculation easier as you can observe in the figure location of ESP header and trailer now let's discuss the second security approach security at transport layer another relatively general purpose solution is to implement security just above the TCP the primary example of this approach is SSL that is secure socket layer and the follow on internet standard known as TLS transport layer security at this level there are two implementation choices for full

Journal SSL could be provided as the part of underlying protocol suite and therefore be transparent to Applications alternatively SSL can be embedded in specific packages for example Netscape Microsoft Explorer browsers come with the SSL and most servers have implemented the protocol as represented in the figure the implementation of SSL and TLS on transport layer so one of the goals of these protocols is to provide server and client authentication data confidentiality and data Integrity application layer client server programs such as HTTP that is hyper text transfer protocol that uses the service of TCP can encapsulate their data in SSL Packets if the server and clients are capable of running SSL or TLS programs

then the client can use the URL https it means hyper text transfer protocol secure instead of the HTTP that is hyper text transfer protocol that allows HTTP message to be encapsulated in SSL packets for example credit card numbers can safely transferred via the internet for online Shoppers as you can observe in SSL Define four protocols in two layers the record protocol is the carrier it carries messages from three other protocols as well as the data coming from the application layer messages from the record Protocols are payload to the transport layer normally TCP the handshake protocol provides security parameters for record protocols it establishes a cipher set and provides key and security parameters it also authenticates the server to the client

and the client to the server if it's required the change Cipher specification protocol is used for signaling the Readiness of the cryptographic secrets the last the alert protocol is used to report abnormal conditions now let's discuss the security Approach at the application layer that is seventh layer in the OSI model application specific Security Services are embedded with the particular applications the advantage of this approach is that service can be tailored to the specific need of given application in the context of web security an important example of this approach is secure electronic transaction set as you can observe in the figure examples of this architecture set on the top of the HTTP this is a common implementation in some implementation set makes uses of TCP

directly two Protocols are used to provide security services for emails that is electronic mails at application layer now first one is pretty good privacy that is pgp and SK pure multi-purpose internet mail extension that is SM smim now let's have a brief discussion on secure electronic transaction Now set is an open encryption and security specification designed to protect credit card transactions on the internet the current version set one emerged from a call for security standards by MasterCard and Visa in Feb 1996 a wide range of companies were involved in developing the initial specifications including big Blues from the America that is IBM Microsoft Netscape RSA beginning in 1996 there have been numerous tests of concept and by 1998 the first wave of

set compliant products was available set is not itself a payment system rather it is a set of security protocols and formats that enables user to employ the existing credit card payment infrastructure on an open network such as the internet in a secure fashion in ESS sense set provides three services first it provides a secure Communication channel among all parties involved in the transaction provides trust by the use of x.509 version 3 digital certificates it ensures privacy because the information is only available to parties in transaction when and where necessary set incorporates the following main features number one confidentiality of information card holders account and payment information is secured as it travel across the network an interesting and important feature of set is that it

prevents the merchant from learning the card holders credit card number this is only provided by the issuing Bank conventional encryption by Dees is used to provide confidentiality now the second feature is integrity of data payment information sent from card holders to Merchants includes order information personal data and payment instructions set guarantees the these messages contents are not altered in transmission RSA digital signature using S1 hash codes providing message integrity certain messages are also protected by hmac using S1 that is cure hash algorithm now the third feature is card holders account authentication set enables Merchants to verify that a card holder is legal user of a valid card account number set uses x.509 version 3

digital certificates with RSA signatures for this purpose now fourth feature is merge Merchant authentication set enables card holder to verify that a merchant has a relationship with the financial institution allowing it to accept payment cards set uses x.509 version 3 digital certificates with RSD signature for this purpose note that unlike IP security and SSL TLS set provides only one choice for each cryptographic algorithm this makes sense because set is a single application with a single set of requirements whereas IP security and SSL tlr intended to support a range of applications email security at application layer can be provided by using pgp that was invented by Phil Zimmerman to provide email with

privacy integrity and authentication pgp can be used to create a secure email messages another Security Service designed for electronic mail is secure multipurpose internet maale extension the protocol is an enhancement of multi-purpose internet maale extension protocol

now let's discuss the next worldwide web security approach that can be implemented in the form of firewalls. Now, firewall is a bit different from previous worldwide web security approaches because all previous security measures cannot prevent sender from sending the harmful messages to the system. To control access to system, we need firewalls. A firewall is a device, usually a router or a dedicated machine, installed between the internal network

of an organization and the rest of the internet. It is designed to forward some packets and filter out some others. You can observe the concept of the firewall from the figure displayed. A firewall may filter all incoming packets for a specific host or specific server such as HTTP. A firewall can be used to deny access to a specific host or a specific service in the organization. A firewall is usually classified as packet filter firewalls or proxy based firewalls. First of all, we will discuss packet filter firewalls. A firewall can be used as a packet filter; it can forward or block packets based upon the information in the network layer and transport layer headers, that is, source and destination IP address, source and destination port numbers, and type of protocol used, that is, TCP or UDP.

A packet filter firewall can be a router that uses a filtering table to decide which packet must be discarded or which must be forwarded. Figure shows an example of filtering table for this kind of firewall. According to the figure, the following packets are filtered: incoming packets from Network 131.34 are blocked; note that 131.34 means the entire network of 131.34.0.0 will be blocked; incoming packets destined for any internal tablet server at Port number 23 are blocked; incoming package destined for internal host 194.

78208 are blocked; the organization wants this host for internal use only; outgoing packets destined for an HTTP sender at Port number 80 are blocked; the organization does not want employees to browse the internet; note that packet filtering firewalls can be divided into two categories: static and stateful firewalls. Static firewalls can be implemented using routers as discussed before, but stateful firewalls can be effectively implemented as standalone firewall devices. Now, the next category is proxy firewalls, the most advanced kind of packet filtering mechanisms ever. The packet filter firewall is based on the information available in the network and transport layer headers, that is, IP address and port numbers. However, sometimes we

need to filter a message based on the information available in the message itself, means at the application layer. As an example, assume that an organization wants to implement the following policies regarding its web page: only those internet users who have previously established business relationship with the company can have access; access to other users must be blocked. In this case, a packet filter firewall is not feasible because it cannot distinguish 24 minutes, 1 second between different packets arriving at Port number 80. Testing must be done at application level using the uniform resource locators. One solution is to install a proxy computer, sometimes called an application gateway, also which stands

between the internal computer and the external computer this machine act as a server to client and client to server the figure displayed shows an application Gateway implementation for hyper text transfer protocol HTTP when the client process sends the message the application Gateway runs a server process to receive the request the server opens the packet at the application Level and finds out if the request is legal if it is the server act as a client process and sends the message to the real server in the external network if it is not the message is dropped and an error message is sent to the external user in this way the requests of the external users are filtered based on the contents at the application layer so in the conclusion we can say as the dependency on

worldwide web is increasing and crucial information is being transferred on worldwide web the need of security is also increasing we have different approaches to address the security issues of worldwide web on Network layer transport layer and application layer and we can use the firewalls also but still user need to be very diligent while using the worldwide web services user awareness can protect him from many threats so stay protected and have a happy browsing that's all for today's session thank you for watching thank you for